

Relatório de Auditoria de Segurança

Gestão DMA — contrato 61/2023

Data: 29/08/2026

Escopo auditado

gestaoDMA · gemoc-frontend · gemoc-backend (backend compartilhado dos dois frontends)

Nota metodológica

Stack detectada: React 19 + Vite + Tailwind v4 + Zustand (frontends: gestaoDMA, gemoc-frontend) · Node.js 22 + Fastify 5 + better-sqlite3 (SQL puro) + Redis/BullMQ (gemoc-backend) · Auth: Firebase Auth (Google) trocado por JWT (cookie HttpOnly) · Deploy: Cloudflare Pages (frontends) + Docker/VM (backend).

Mapeamento das categorias para a stack:

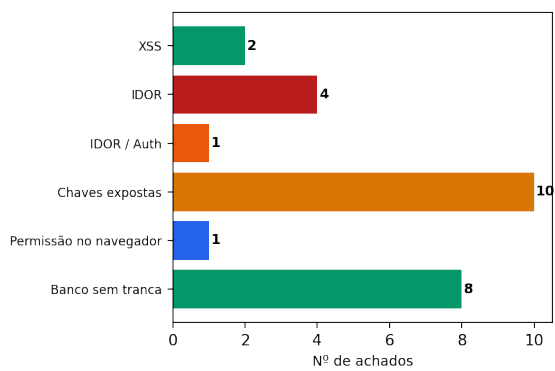
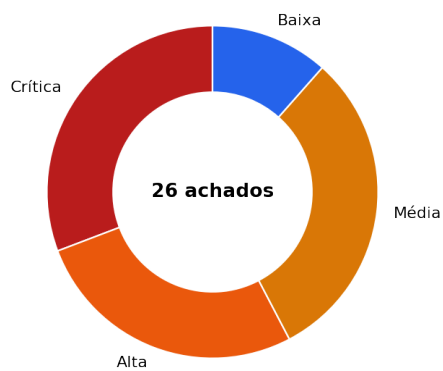
- 1. Banco sem tranca → como não há ORM, verificamos o isolamento nas queries SQL puras (better-sqlite3) dos repositories e no escopo de contrato (61/2023).
- 2. Permissão no navegador → cruzamos gates de papel do frontend (isAdmin/user.tipo) com os preHandler do backend (authenticate/requireAdmin).
- 3. IDOR → percorremos todos os handlers de routes/ buscando acesso a objetos/arquivos por ID/path/hash sem verificação de posse ou contrato.
- 4. Chaves expostas → varredura de segredos hardcoded em código, .env*, configs, scripts, gitignore e histórico git.
- 5. Inputs sem tratamento (XSS) → innerHTML/dangerouslySetInnerHTML no frontend e interpolação sem escape no HTML gerado pelo backend.

Auditoria de código estático sobre o estado atual do repositório (branch main / feature/novo-tema-azul-logo).

Resumo Executivo

Total de **26** achados: **8 críticos**, **7 altos**, **8 médios**, **3 baixos**. Foram verificados também **12 pontos fortes** (controles que funcionam corretamente).

Severidade	Qtd	Cor
Crítica	8	
Alta	7	
Média	8	
Baixa	3	



Pontos Fortes (verificados e protegidos)

- `requireAdmin` funcional (`auth.middleware.js:90-108`) — rotas de `admin/sync/deploy/recache/documentos-DELETE` corretamente protegidas.
- `safeResolve()` com prefixo+separador em `medicoes`, `documentos-contrato` e `fichas` (bloqueia path traversal e `../`).
- Tokens HMAC auto-contidos (`fichas`, `medicoes`, `documentos-contrato`) com expiração, não forjáveis sem `secret`.
- Whitelist de tabelas no `gemocdocs.repository.js` (sem SQLi por tabela arbitrária) e whitelist de `sortKey` em `gestores`.
- Helmet + cookie JWT `HttpOnly/SameSite` + `rate-limit` no login (5/min) + `delay anti-brute-force`.
- Fail-fast no startup: valida `JWT_SECRET` e `ENCRYPTION_KEY` antes de iniciar.
- Error handler global não expõe stack trace em produção.
- Firestore fallback seguro: se indisponível, assume tipo `user` (nunca `admin`).
- Banco `gestaodma` isolado (`gestaodma.database.js`) já contém apenas dados do 61/2023.
- `sheetToHtml/xlsxToHtml` escapam `&`, `<`, `>` (`fichas.routes.js:482`; `documentos.routes.js:236`).
- Sem `eval/new Function/document.write/javascript:` URI nos 3 projetos.
- `sei-monitor-sync` com token estático dedicado para escrita.

Riscos Centrais (pontos fracos)

- Autenticação forjável: o ID token Firebase não tem assinatura validada no backend (bypass amplifica tudo).
- Diversas rotas públicas: `gestores`, `municípios` e `documentos` servem dados/PII sem login.
- Segredos de produção reais commitados no repositório (`JWT_SECRET`, chave SSH, token Cloudflare, credenciais SEI).
- Sem isolamento de escopo: os endpoints retornam a carteira inteira; o filtro 61/2023 só existe no frontend.
- Path traversal em `/fichas/debug-date` e acessos cross-contrato a arquivos (`fichas`, `medições`, `documentos`).

Tabela de Achados por Categoria

Banco sem tranca

Sev	Arquivo:linha	Descrição
Crítica	backend/routes/gestores.routes.js:104,137-179,449	7279-449 gestores sem autenticação expõem PII de toda a carteira. GET /gestores, /gestores/stats, /gestores/por...
Crítica	backend/routes/municipios.routes.js:13,118,154	8154 de municípios sem autenticação, agora expõem processo SEI via detalhado=1. GET /municipios, /municipi...
Alta	backend/repositories/contrato.repository.js:256-327	326-327 contratos e /api/stats/bloco retornam carteira inteira. findContratos() consulta FROM STATUS sem restr...
Alta	backend/repositories/medicao.repository.js:20,95-104,106,170-238	20,95-104,106,170-238 de todos os contratos; novo /medicoes/todas junta SMO + meta.js...
Alta	backend/routes/documentos-contrato.routes.js:13,75-100	13,75-100 documentos agora itera todos os contratos (commit 116bd102). Antes lia só 61-2023/meta.json; agora ite...
Alta	backend/repositories/dashboard.repository.js:5-233	5-233 stats/charts/financeiro/sections sem filtro de contrato. KPIs e gráficos globais de toda a carteira (conta...
Alta	backend/routes/export.routes.js:390-431	Exportação de medições por segmento sem filtro de contrato. fetchSegmentData() e download geram XLSX com...
Baixa	backend/routes/sei.routes.js:6-13; gemoc-backend/routes/sei.routes.js:1-9	6-13, 1-9 Processos SEI e tabelas GemocDocs sem escopo de contrato. Acesso a todos os processos SEI e todas as tabe...

Permissão no navegador

Sev	Arquivo:linha	Descrição
Crítica	backend/routes/admin.routes.js:42-45	42-45 Bull Board (filas Redis) exposto sem autenticação. O dashboard de filas Bull (serverAdapter.registerPlugin) é regi...

IDOR

Sev	Arquivo:linha	Descrição
Alta	backend/routes/fichas.routes.js:662-694	662-694 Path traversal em /fichas/debug-date. req.query.path é resolvido com path.resolve sem validação startsWith(FICH...
Alta	backend/routes/fichas.routes.js:974-1023, F039-1063	974-1023, F039-1063 download por path de qualquer contrato, check fraco. startswith(FICHAS_DIR) sem path.sep permite...
Média	backend/routes/acompanhamento.routes.js:113-155, 171	113-155, 171 de demandas/equipe por ID sem admin ou posse. DELETE /acompanhamento/demandas/:id com a...
Média	backend/routes/medicoes.routes.js:100-142	100-142 Deletar público e download de cartas.js:97-129 path sem escopo de contrato. safeResolve bloqueia traversal (ponto fo...

Chaves expostas

Sev	Arquivo:linha	Descrição
Crítica	backend/.env.example:22,27-28,35,57 (tanto JWT_SECRET=ENCR/PTMOM/KR)	22,27-28,35,57 JWT_SECRET=ENCR/PTMOM/KR, AUTH_PASS e DEPLOY_PATH reais commitados em .env.example. JWT_...
Crítica	tokenflare.txt (commitado)	Token Cloudflare cfut_ commitado. Arquivo tokenflare.txt com token real da API Cloudflare commitado e não cobr...
Crítica	vmoracle.key (commitado)	Chave privada RSA de acesso à VM commitada. Arquivo contém "-----BEGIN RSA PRIVATE KEY-----". Adicionac...
Crítica	gemoc-backend/Tools/electron/scripts/credentials	credentials reais do SEI commitadas. login=luucas.nlopes / senha=@Goinfra2026 commitados. .gitignore não cobr...
Média	gestaoDMA/src/services/firebase.js:13-19	Fallback hardcoded aponta para projeto Firebase errado (gemoc-login). Se VITE_FIREBASE_* não carregar, usa...
Média	gestaoDMA/.env.development	Firebase API key commitada em .env.development. VITE_FIREBASE_* commitados; .gitignore não cobre .env.de...
Média	backend/routes/fichas.routes.js:575; document.cookie	575, document.cookie Fallback hardcoded aponta para projeto Firebase errado (gemoc-login). Se VITE_FIREBASE_* não carregar, usa...
Média	backend/server.js:105	frameguard desativado globalmente (clickjacking off). O commit 6b42a265 adicionou frameguard: false ao helmet...
Baixa	gemoc-backend/gemoc-backend/backend/server.js:166	166 Senha padrão hardcoded no código. if (process.env.AUTH_USER === 'admin' && process.env.AUTH_PASS ===...
Baixa	gemoc-backend/backend/_tmp_142.cjs (commitado)	_tmp_142.cjs porário com caminho absoluto da máquina commitado. Arquivo _tmp_142.cjs contém caminho absoluto...

XSS

Sev	Arquivo:linha	Descrição
Média	gestaoDMA/src/components/portfolio/Slide.dangerouslySetInnerHTML	dangerouslySetInnerHTML sanitização. SVG do pptx é injetado via dangerouslySetInnerHTML. do...
Média	gemoc-backend/backend/scripts/ficha-htm	29-30 banco interpolados em HTML sem escape. Contrato, empresa, objeto, nome de gestor e observações...

Recomendações Priorizadas

[P1] Rotacionar imediatamente todos os segredos expostos: JWT_SECRET, ENCRYPTION_KEY, AUTH_PASS, chave RSA (vmoracle.key), token Cloudflare, credenciais SEI.

[P1] Remover do repositório e do histórico git: tokenflare.txt, vmoracle.key, credenciais.txt, e valores reais de .env.example (BFG Repo-Cleaner).

[P1] Validar assinatura do ID token Firebase no backend (firebase-admin) — elimina o bypass de autenticação que amplifica todos os demais riscos.

[P1] Adicionar autenticação (authenticate) às rotas públicas: /gestores/*, /municipios/*, /documentos/view/:hash, /documentos/pdf/:hash e ao Bull Board (requireAdmin).

[P2] Corrigir path traversal em /fichas/debug-date e reforçar o check de prefixo em /fichas/view e /fichas/download (safeResolve + path.sep).

[P2] Aplicar isolamento de escopo: restringir endpoints de listagem/agregação/exportação ao contrato 61/2023 (ou RBAC por permissão).

[P2] Adicionar requireAdmin ou validação de posse em PUT/DELETE de acompanhamento e no acesso a arquivos (medicoes, documentos-contrato, fichas) validando o contrato.

[P3] Sanitizar SVG (SlideViewer) com dompurify e escapar saída HTML em ficha-html.js.

[P3] Remover fallbacks hardcoded de HMAC secret e de credenciais Firebase; exigir variáveis de ambiente.

[P3] Adicionar .env.development e tokenflare.txt ao .gitignore; remover senha padrão hardcoded de server.js.

Legenda P1: corrigir imediatamente (risco crítico). P2: corrigir em curto prazo. P3: melhorias de endurecimento.

Issues para o GitHub

Issue 1 · Critica

```
--- ISSUE 1 ---
**Titulo:** [[Segurança] Rotas de gestores e municípios sem autenticação expõem PII da carteira]
**Labels sugeridas:** security, critica
**Descricao do problema:**
As rotas GET /api/gestores*, GET /api/municipios* e o Bull Board não possuem preHandler de autenticação. Qualquer pessoa não autenticada pode listar nomes de gestores/fiscais, portarias, datas e medições municipais de toda a carteira de contratos, sem restrição ao contrato alvo 61/2023.
Evidência:
- backend/routes/gestores.routes.js:100,133,275,486
- backend/routes/municipios.routes.js:12,58,78
- backend/routes/admin.routes.js:42-45 (Bull Board)
**Impacto:**
Exposição de dados pessoais (LGPD) e da carteira completa; controle de filas de produção.
**Sugestao de correcao:**
Adicionar preHandler: [authenticate] em todas essas rotas e requireAdmin no Bull Board; restringir o escopo de consulta ao contrato 61/2023.
**Criterios de aceite (checklist):**
- [ ] Rotas /gestores* exigem login
- [ ] Rotas /municipios* exigem login
- [ ] Bull Board exige admin
- [ ] Teste manual sem token retorna 401
--- FIM ISSUE 1 ---
```

Issue 2 · Critica

```
--- ISSUE 2 ---
**Titulo:** [[Segurança] ID token Firebase aceito sem verificação de assinatura (bypass de autenticação)]
**Labels sugeridas:** security, critica
**Descricao do problema:**
O backend decodifica o payload do Firebase JWT em base64 e valida apenas exp/iss, sem verificar a assinatura RS256 contra as chaves públicas do Google. Qualquer atacante pode forjar um token com aud/firebase e exp futuro, autenticando como qualquer uid.
Evidência:
- backend/routes/auth.routes.js:128-169
- backend/middleware/auth.middleware.js:65-81
**Impacto:**
Bypass total de autenticação; permite explorar todas as demais falhas de autorização.
**Sugestao de correcao:**
Validar a assinatura do ID token com firebase-admin (verifyIdToken) ou com as chaves públicas do projeto.
**Criterios de aceite (checklist):**
- [ ] verifyIdToken usado no login
- [ ] Token forjado rejeitado (teste)
- [ ] exp/iss/aud validados
--- FIM ISSUE 2 ---
```

Issue 3 · Critica

```
--- ISSUE 3 ---
**Titulo:** [[Segurança] Segredos reais commitados (JWT_SECRET, ENCRYPTION_KEY, AUTH_PASS, chave SSH, token Cloudflare, credenciais SEI)]
**Labels sugeridas:** security, critica
**Descricao do problema:**
Arquivos commitados contêm segredos de produção reais: backend/.env.example (JWT_SECRET, ENCRYPTION_KEY, AUTH_PASS), tokenflare.txt (token Cloudflare), vmoracle.key (chave privada SSH), Tools/electron/scripts/credenciais.txt (senha SEI).
Evidência:
- backend/.env.example:22,27-28,35,57
- tokenflare.txt
- vmoracle.key
- gemoc-backend/Tools/electron/scripts/credenciais.txt
```

```

**Impacto:**
Forja de tokens admin, descriptografia LGPD, acesso SSH à VM e acesso ao SEI.
**Sugestao de correcao:**
Rotacionar todos os segredos, removê-los do histórico (BFG), substituir .env.example por
placeholders e atualizar .gitignore.
**Critérios de aceite (checklist):**
- [ ] Segredos rotacionados
- [ ] Removidos do histórico git
- [ ] .env.example só com placeholders
- [ ] .gitignore cobre tokenflare/credenciais
--- FIM ISSUE 3 ---

```

Issue 4 · Alta

```

--- ISSUE 4 ---
**Titulo:** [[Segurança] Path traversal em /fichas/debug-date e check fraco em
/fichas/view|download]
**Labels sugeridas:** security, alta
**Descricao do problema:**
A rota /fichas/debug-date resolve req.query.path com path.resolve sem validar prefixo,
permitindo ../ para ler .xlsx arbitrários do servidor. As rotas view/download usam startsWith sem
path.sep, permitindo bypass por diretório irmão.
Evidência:
- backend/routes/fichas.routes.js:662-694,974-1023,1039-1063
**Impacto:**
Leitura arbitrária de arquivos do servidor e acesso cross-contrato.
**Sugestao de correcao:**
Reutilizar safeResolve() com validação de prefixo + separador e validar posse do contrato.
**Critérios de aceite (checklist):**
- [ ] debug-date usa safeResolve
- [ ] view/download validam contrato
- [ ] Teste com ../ retorna 403
--- FIM ISSUE 4 ---

```

Issue 5 · Alta

```

--- ISSUE 5 ---
**Titulo:** [[Segurança] Documentos servidos por hash sem autenticação (/documentos/view/:hash,
/documentos/pdf/:hash)]
**Labels sugeridas:** security, alta
**Descricao do problema:**
As rotas de visualização e conversão de documentos não possuem preHandler. Como GET /documentos
(authenticado) lista todos os hashes, um hash vazado dá acesso a arquivos de qualquer contrato sem
login.
Evidência:
- backend/routes/documentos.routes.js:359,366
**Impacto:**
Vazamento de documentos de todos os contratos.
**Sugestao de correcao:**
Adicionar authenticate e validar posse do documento pelo contrato do usuário.
**Critérios de aceite (checklist):**
- [ ] view/pdf exigem login
- [ ] Posse validada por contrato
- [ ] Teste sem token retorna 401
--- FIM ISSUE 5 ---

```

Issue 6 · Media

```

--- ISSUE 6 ---
**Titulo:** [[Segurança] XSS: SVG sem sanitização (SlideViewer) e HTML de ficha sem escape
(ficha-html.js)]
**Labels sugeridas:** security, media
**Descricao do problema:**
O SVG gerado pelo pptx é injetado via dangerouslySetInnerHTML sem sanitização (dompurify não
usado). Dados de contrato/gestor/objeto entram no HTML da ficha sem escape.
Evidência:
- gestaoDMA/src/components/portfolio/SlideViewer.jsx:164 (e gemoc-frontend)

```

```
- gemoc-backend/backend/scripts/ficha-html.js:29-91
**Impacto:**
Execução de script no contexto do usuário (XSS armazenado).
**Sugestao de correcao:**
Sanitizar com dompurify e escapar a saída HTML da ficha.
**Critérios de aceite (checklist):**
- [ ] dompurify aplicado no SVG
- [ ] ficha-html.js escapa entradas
- [ ] Teste com script no PPTX/dado
--- FIM ISSUE 6 ---
```

Issue 7 • Media

```
--- ISSUE 7 ---
**Titulo:** [[Segurança] Sem isolamento de escopo: endpoints retornam carteira inteira, não só 61/2023]
**Labels sugeridas:** security, media
**Descricao do problema:**
Contratos, stats, medições, dashboard, OS, portfolio e exportações retornam dados de todos os contratos. O filtro por 61/2023 é feito apenas no frontend (gestaoDMA), sem barreira no backend.
Evidência:
- backend/repositories/contrato.repository.js:266-626
- backend/repositories/medicao.repository.js:20-95
- backend/repositories/dashboard.repository.js:5-233
- backend/routes/export.routes.js:390-431
**Impacto:**
Exposição da carteira completa a qualquer usuário autenticado.
**Sugestao de correcao:**
Adicionar isolamento por contrato/permissão (RBAC) nos endpoints de leitura e exportação.
**Critérios de aceite (checklist):**
- [ ] Endpoints filtram por contrato alvo
- [ ] Exportações escopadas
- [ ] Teste de permissão com usuário comum
--- FIM ISSUE 7 ---
```